

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (NVD CVSS-weighted) · Generated 2026-06-11 · Model: $0.5 \cdot \text{CVE} + 0.3 \cdot \text{exposure} + 0.2 \cdot \text{criticality}$

Ranked remediation backlog (pre-fix)

#	Coordinate	Ver	Band	Risk Score	Top CVE	Fix
1	com.fasterxml.jackson.core:jackson-databind	2.9.8	CRITICAL	8.4	CVE-2019-14379 (9.8) — 107 CVEs	2.18.3
2	org.apache.logging.log4j:log4j-core	2.14.1	CRITICAL	8.0	CVE-2021-44228 (10.0) — 15 CVEs	2.23.1
3	mysql:mysql-connector-java	8.0.30	HIGH	7.5	CVE-2023-22102 (8.3)	coord change
4	commons-io:commons-io	2.4	HIGH	7.3	GHSA-78wr-2p64-hpwj (7.5)	2.18.0
5	org.apache.logging.log4j:log4j-api	2.14.1	HIGH	7.0	CVE-2026-34479 (7.5)	2.23.1
6	com.google.guava:guava	24.1.1-jre	HIGH	6.8	CVE-2023-2976 (7.1)	33.4.0-jre
7	com.google.protobuf:protobuf-java	3.19.4	HIGH	6.4	CVE-2024-7254 (8.7)	major review
8	com.fasterxml.jackson.core:jackson-annotations	2.9.0	HIGH	6.0	CVE-2018-	2.18.3 (pinner)

					1000873 (6.5)	
9	org.apache.commons:commons-lang3	3.4	HIGH	6.0	GHSA-j288-q9x7-2f5v (6.5)	3.17.0 ✓

Legend: ✓ auto-applied in this PR · ⚠ MAJOR_REVIEW — tracking issue opened

Component score breakdown

Dependency	CVE severity (×0.5)	Exposure (×0.3)	Business criticality (×0.2)	Weighted score
jackson-databind 2.9.8	10.0	8.0	5.0	8.4
log4j-core 2.14.1	10.0	8.0	3.0	8.0
mysql-connector-java 8.0.30	8.8	7.0	5.0	7.5
commons-io 2.4	9.0	8.0	2.0	7.3
log4j-api 2.14.1	8.0	8.0	3.0	7.0
guava 24.1.1-jre	8.6	7.0	2.0	6.8
protobuf-java 3.19.4	9.0	5.0	2.0	6.4
jackson-annotations 2.9.0	6.5	6.0	5.0	6.0
commons-lang3 3.4	7.0	7.0	2.0	6.0

Auto-remediation outcome (this PR)

7 of 9 packages auto-remediated · 2 flagged MAJOR_REVIEW

Dependency	Change	CVEs cleared	Result
jackson-databind	2.9.8 → 2.18.3	107 CVEs (CVSS 9.8 CRITICAL)	APPLIED
log4j-core	2.14.1 → 2.23.1	CVE-2021-44228 (Log4Shell, 10.0)	APPLIED
log4j-api	2.14.1 → 2.23.1	CVE-2026-34479	APPLIED
commons-io	2.4 → 2.18.0	GHSA-78wr-2p64-hpwj	APPLIED

commons-lang3	3.4 → 3.17.0	GHSA-j288-q9x7-2f5v	APPLIED
guava	24.1.1-jre → 33.4.0-jre	CVE-2023-2976	APPLIED
jackson-annotations	pinned to 2.18.3 (mgmt)	CVE-2018-1000873	APPLIED
mysql-connector-java	—	CVE-2023-22102 persists	MAJOR_REVIEW — coordinate change to com.mysql:mysql-connector-j required
protobuf-java	—	CVE-2024-7254 persists	MAJOR_REVIEW — 3.x→4.x major version API review needed
com.fastxml typosquat	REMOVED	n/a (supply-chain)	APPLIED
Untrusted HTTP repo	REMOVED	n/a (supply-chain)	APPLIED

Note: *log4j 2.23.1 carries 5 new MEDIUM CVEs (CVE-2025-68161, CVE-2026-34477-34480, CVSS 6.3–6.9) discovered after 2.14.1's original Log4Shell advisories. These are a significant improvement over the pre-fix CRITICAL/HIGH exposure. No patch version between 2.14.1 and 2.23.1 clears all of them; upgrading to the latest stable release is the correct action. Track for the next log4j patch release.*

Machine-readable source: `depscan-risk-report.json` . Generated by the Dependency & Supply-Chain Plugin — Stage 2 run 2026-06-11.